

QuoteCraft Architecture Review

Executive Summary

- QuoteCraft does not meet Silver tier availability requirements: single-replica deployment, single-AZ database/cache, and missing DR testing.
- Security controls are incomplete: secrets are injected via environment variables, image tags are not pinned, and long-lived AWS keys are present.
- Cost controls are breached: EFS uses provisioned throughput without justification, and non-production spend exceeds policy thresholds.
- Scalability is limited by in-memory rate limiting, which prevents safe horizontal scaling.
- Several documentation and implementation conflicts exist, requiring clarification and remediation.

Findings

Cost

F-01: EFS Provisioned Throughput Without Justification

- Severity: High
- Dimension: Cost
- Evidence:
- Source: app:docs/capacity-plan.md
- Quote: "Throughput mode: provisioned, 200 MiB/s"
- Policy reference: FIN-06
- Why it matters: Provisioned throughput incurs significant cost and is only allowed when justified by documented IOPS requirements. The capacity plan notes that PDF generation is not I/O bound, so this is likely waste.
- Remediation: Revert EFS to burst mode unless a documented IOPS requirement is provided and approved.
- Confidence: High

F-02: Non-Production Spend Exceeds Policy Threshold

- Severity: High
- Dimension: Cost
- Evidence:
- Source: case:hackathon-assets/hackathon-quotecraft-intake-form.pdf
- Quote: "FinOps team flagged in March 2026 that QuoteCraft's non-production environment is consuming approximately 35% of what production consumes."
- Policy reference: FIN-07
- Why it matters: Non-production spend must not exceed 20% of production. Overspending triggers a FinOps review and indicates waste or misconfiguration.
- Remediation: Investigate non-production resource sizing and scheduling; reduce to policy-compliant levels.
- Confidence: High

F-03: S3 Archive Lacks Lifecycle Policy for Cold Storage

- Severity: Medium
- Dimension: Cost
- Evidence:
- Source: app:infra/aws/s3.tf
- Quote: "# NB: No lifecycle configuration. Quote archives are kept in STANDARD storage class indefinitely."
- Policy reference: FIN-13
- Why it matters: Keeping long-term archives in standard storage increases cost. Policy requires lifecycle policies to transition infrequently-accessed data to colder storage classes.
- Remediation: Add a lifecycle policy to transition quote archives to Glacier or equivalent after 30 days.
- Confidence: High

Security

F-04: Secrets Injected via Environment Variables

- Severity: Critical
- Dimension: Security
- Evidence:
- Source: app:deploy/openshift/deployment.yaml
- Quote: "envFrom: ... secretRef: name: quotecraft-secrets" and "valueFrom: secretKeyRef:"
- Policy reference: CKS-11, DCH-07
- Why it matters: Injecting secrets as environment variables is prohibited due to risk of accidental disclosure in logs, dumps, or process listings.
- Remediation: Refactor manifests and application to mount secrets as file volumes only.
- Confidence: High

F-05: Use of Long-Lived AWS Access Keys

- Severity: High
- Dimension: Security

- Evidence:
- Source: app:deploy/openshift/secret-aws-keys.yaml
- Quote: "# Long-lived IAM user access keys for reading from AWS Secrets Manager and mounting EFS. Created by the initial platform onboarding. There's a ticket to migrate to IRSA (QC-203) but it's not scheduled yet."
- Policy reference: AHS-11, ASC-06
- Why it matters: Long-lived credentials are a major security risk and explicitly prohibited. Workload identity federation must be used.
- Remediation: Prioritize migration to IRSA or equivalent workload identity for AWS access.
- Confidence: High

F-06: Container Image Tag Not Pinned

- Severity: High
- Dimension: Security
- Evidence:
- Source: app:deploy/openshift/deployment.yaml
- Quote: "image: quotecraft:latest"
- Policy reference: CKS-06
- Why it matters: Using the `:latest` tag is prohibited in production/pre-production as it can lead to unintentional upgrades and makes provenance tracking impossible.
- Remediation: Pin image tags by digest or semantic version in all manifests.
- Confidence: High

F-07: Redis Transit Encryption Disabled

- Severity: High
- Dimension: Security
- Evidence:
- Source: app:infra/aws/elasticache.tf
- Quote: "# NB: TLS in transit is not enabled. Enabling it would require an application change (rediss:// URL and CA bundle). Tracked in QC-176."
- Policy reference: ASC-05, DCH-04
- Why it matters: Redis contains session and PII data. Lack of TLS in transit exposes sensitive data to

interception.

- Remediation: Enable Redis transit encryption and update application to use `rediss://`.
- Confidence: High

F-08: Bureau API Certificate Verification Disabled

- Severity: High
- Dimension: Security
- Evidence:
- Source: app:src/quotecraft/integrations/bureau.py
- Quote: "response = requests.post(url, ..., verify=False)"
- Policy reference: DCH-05
- Why it matters: Disabling certificate verification exposes the application to man-in-the-middle attacks when calling the credit bureau.
- Remediation: Update the base image trust store and set `verify=True` for the bureau API.
- Confidence: High

F-09: Secrets Manager Source of Truth Is Unclear

- Severity: Medium
- Dimension: Security
- Evidence:
- Source: app:docs/architecture.md
- Quote: "Secrets are sourced from Azure Key Vault via the External Secrets Operator."
- Source: app:docs/runbook.md
- Quote: "Secrets are managed in HashiCorp Vault."
- Policy reference: CKS-10
- Why it matters: Unclear or conflicting documentation on secrets management increases operational risk and complicates incident response.
- Remediation: Standardize and document the authoritative secrets manager and update all references.
- Confidence: Medium

F-10: Overly Broad RBAC Role for Operator ServiceAccount

- Severity: Medium

- Dimension: Security
- Evidence:
- Source: app:deploy/openshift/rbac.yaml
- Quote: "apiGroups: [\"*\"], resources: [\"*\"], verbs: [\"*\"]"
- Policy reference: CKS-14
- Why it matters: Wildcard RBAC permissions are prohibited; they increase blast radius in case of compromise.
- Remediation: Restrict Role to only required resources and verbs.
- Confidence: High

Scalability

F-11: In-Memory Rate Limiter Prevents Safe Horizontal Scaling

- Severity: High
- Dimension: Scalability
- Evidence:
- Source: app:docs/runbook.md
- Quote: "This is a known issue with the current in-memory rate limiter when the service is scaled to multiple pods."
- Policy reference: ARS-14
- Why it matters: In-memory rate limiting is not safe for multi-replica deployments, leading to inconsistent enforcement and risk of overload.
- Remediation: Move rate limiter state to Redis or another external store.
- Confidence: High

F-12: No HorizontalPodAutoscaler Defined in Manifests

- Severity: Medium
- Dimension: Scalability
- Evidence:
- Source: app:deploy/openshift/deployment.yaml
- Quote: "No HPA resource present."
- Policy reference: ARS-12

- Why it matters: Silver tier requires HPA for traffic variation. Absence means manual scaling is needed and risks SLO breaches.
- Remediation: Define and deploy a HorizontalPodAutoscaler for the main deployment.
- Confidence: High

Availability

F-13: Single-Replica Deployment Breaches Silver Tier

- Severity: Critical
- Dimension: Availability
- Evidence:
- Source: app:deploy/openshift/deployment.yaml
- Quote: "replicas: 1"
- Policy reference: ARS-02, ARS-13
- Why it matters: Silver tier requires a minimum of three replicas, distributed across AZs. Single replica is a single point of failure.
- Remediation: Increase replica count to at least three and ensure multi-AZ placement.
- Confidence: High

F-14: No Topology Spread Constraints; Pods Pinned to One Zone

- Severity: High
- Dimension: Availability
- Evidence:
- Source: app:deploy/openshift/deployment.yaml
- Quote: "failure-domain.alpha.paas.com/zone: '1'"
- Policy reference: ARS-05
- Why it matters: All pods in one AZ means an AZ outage will cause total service loss.
- Remediation: Remove hard zone pinning and add topologySpreadConstraints for multi-AZ distribution.
- Confidence: High

F-15: PostgreSQL and Redis Not Highly Available

- Severity: High
- Dimension: Availability
- Evidence:
- Source: app:docs/capacity-plan.md
- Quote: "High availability: single-zone (see \"Open items\" below)" and "Nodes: 1 (single-AZ)"
- Policy reference: ARS-18, ASC-04
- Why it matters: Single-AZ database and cache are not resilient to AZ failure, breaching Silver tier requirements.
- Remediation: Enable zone-redundant HA for Postgres and deploy Redis with replicas in multiple AZs.
- Confidence: High

F-16: DR Exercise Not Performed; Runbook Incomplete

- Severity: High
- Dimension: Availability
- Evidence:
- Source: app:docs/capacity-plan.md
- Quote: "DR exercise: **not yet performed.** Scheduled for Q3 2026."
- Source: app:docs/runbook.md
- Quote: "Single-AZ loss TODO. Full region loss TODO."
- Policy reference: ARS-20, ARS-21, ARS-22
- Why it matters: DR testing is required annually for Silver tier. Lack of tested procedures increases risk of extended outages.
- Remediation: Complete DR exercise and update runbook with tested recovery steps.
- Confidence: High

F-17: Liveness Probe Exercises Database (Cascading Failure Risk)

- Severity: Medium
- Dimension: Availability
- Evidence:
- Source: app:deploy/openshift/deployment.yaml
- Quote: "livenessProbe: httpGet: path: /health/deep"
- Source: app:docs/runbook.md

- Quote: "Used as both the readiness and liveness probe by Kubernetes."
- Policy reference: ARS-07
- Why it matters: Liveness probes must not check external dependencies. This can cause healthy pods to be restarted during DB incidents, amplifying outages.
- Remediation: Separate liveness (shallow) and readiness (deep) probes.
- Confidence: High

F-18: PostgreSQL Backup Retention Below Silver Requirement

- Severity: Medium
- Dimension: Availability
- Evidence:
- Source: app:docs/capacity-plan.md
- Quote: "Backup retention: 7 days"
- Policy reference: ARS-15
- Why it matters: Silver tier requires 30-day backup retention. 7 days is insufficient for regulatory and operational recovery.
- Remediation: Increase backup retention to at least 30 days.
- Confidence: High

Highest Priority Next Actions

1. Refactor deployment manifests and application to mount all secrets as file volumes (not environment variables) and remove long-lived AWS keys (migrate to workload identity).
2. Increase application replica count to at least three, remove single-zone pinning, and add topology spread constraints for multi-AZ deployment.
3. Enable zone-redundant high availability for PostgreSQL and deploy Redis with multi-AZ replication and transit encryption.
4. Implement a distributed rate limiter (e.g., Redis-backed) to support safe horizontal scaling.
5. Complete the scheduled DR exercise, update the runbook with tested recovery steps, and remediate all open DR/HA gaps.

****Note:**** Several findings are interdependent (e.g., multi-AZ, HPA, and rate limiting). Addressing them

together will maximize risk reduction and compliance.